

QCM - Gestion d'Intrusion

Instructions

- Chaque question comporte une ou plusieurs bonnes réponses
 - Les réponses correctes sont indiquées à la fin de chaque section
-

PARTIE 1 : Origine de la Cybersécurité (15 questions)

Q1. Quel est le premier programme auto-répliquatif créé en 1971 ?

- A) Morris Worm
- B) Creeper
- C) ILOVEYOU
- D) Melissa

Q2. Qui a développé le programme Creeper ?

- A) Robert Tappan Morris
- B) Bob Thomas (BBN)
- C) Kevin Mitnick
- D) John McAfee

Q3. Quel message affichait Creeper ?

- A) "You've been hacked!"
- B) "I'm the creeper, catch me if you can!"
- C) "Your files are encrypted"
- D) "System compromised"

Q4. Combien de machines le Morris Worm a-t-il infectées en 1988 ?

- A) 600
- B) 6 000
- C) 60 000
- D) 600 000

Q5. Quelles vulnérabilités exploitait le Morris Worm ?

- A) Failles dans sendmail, finger, mots de passe UNIX
- B) Failles dans Windows
- C) Vulnérabilités SSL
- D) Failles dans Apache

Q6. En quelle année les premiers antivirus sont-ils apparus ?

- A) 1985
- B) 1987
- C) 1990
- D) 1995

Q7. Quelle organisation a été créée en 1988 suite au Morris Worm ?

- A) NSA
- B) CERT (Computer Emergency Response Team)
- C) FBI Cyber Division
- D) ANSSI

Q8. En quelle année TCP/IP a-t-il été standardisé ?

- A) 1975
- B) 1980
- C) 1983
- D) 1990

Q9. Quel algorithme de chiffrement asymétrique a été introduit en 1977 ?

- A) AES
- B) DES
- C) RSA
- D) SHA

Q10. Qu'est-ce que la Triade CIA ?

- A) Central Intelligence Agency
- B) Confidentialité, Intégrité, Disponibilité
- C) Computer, Internet, Application
- D) Cryptography, Identification, Authentication

Q11. Quel modèle de sécurité caractérise les années 1990 ?

- A) Zero Trust
- B) Sécurité périmétrique (château fort)
- C) DevSecOps
- D) Cloud Security

Q12. Quelle approche caractérise les années 2000 ?

- A) Sécurité locale uniquement
- B) Défense en profondeur
- C) Zero Trust
- D) Pas de sécurité

Q13. Quel concept est apparu dans les années 2010-2020 ?

- A) Premiers antivirus
- B) Zero Trust ("Never trust, always verify")
- C) Premiers pare-feu
- D) TCP/IP

Q14. Quelle est une tendance actuelle en cybersécurité ?

- A) Sécurité uniquement locale
- B) IA/ML pour la détection des menaces
- C) Abandon des pare-feu
- D) Pas de chiffrement

Q15. Que signifie XDR ?

- A) eXtreme Data Recovery
 - B) Extended Detection and Response
 - C) eXternal Defense Router
 - D) eXtra Data Replication
-

RÉPONSES PARTIE 1

Q	Réponse
1	B
2	B
3	B
4	B
5	A
6	B
7	B
8	C
9	C
10	B
11	B
12	B
13	B
14	B
15	B

PARTIE 2 : Détection d’Intrusion (20 questions)

Q16. Qu’est-ce que la détection d’intrusion ?

- A) Un antivirus
- B) Le processus d’identification d’activités malveillantes ou anormales
- C) Un pare-feu
- D) Un système de backup

Q17. Que signifie MTTD ?

- A) Maximum Time To Deploy
- B) Mean Time To Detect

- C) Minimum Time To Delete
- D) Mean Time To Destroy

Q18. Pourquoi la détection est-elle essentielle aujourd'hui ?

- A) Les pare-feu suffisent
- B) Les attaques contournent les défenses périmétriques
- C) Il n'y a plus d'attaques
- D) Les antivirus détectent tout

Q19. Quel type de détection est basé sur des règles connues ?

- A) Détection comportementale
- B) Détection par signature
- C) Détection par IA
- D) Détection aléatoire

Q20. Quel est l'inconvénient majeur de la détection par signature ?

- A) Trop lente
- B) Inefficace face aux zero-day
- C) Trop coûteuse
- D) Nécessite trop de ressources

Q21. Quel type de détection est adapté aux APT ?

- A) Détection par signature uniquement
- B) Détection comportementale (anomalies)
- C) Pas de détection possible
- D) Détection manuelle uniquement

Q22. Quels algorithmes sont utilisés pour la détection basée IA ?

- A) MD5, SHA
- B) RF, KNN, CNN, LSTM
- C) RSA, AES
- D) TCP, UDP

Q23. Que signifie NIDS ?

- A) Network Intrusion Detection System
- B) New Internet Defense System
- C) National ID Security
- D) Network ID Scanner

Q24. Que signifie HIDS ?

- A) Hardware ID System
- B) Host Intrusion Detection System
- C) High-level IDS
- D) Hybrid IDS

Q25. Quelle est la fonction d'un IPS ?

- A) Analyse uniquement
- B) Prévention inline (blocage)
- C) Backup
- D) Chiffrement

Q26. Que signifie SIEM ?

- A) Security Information and Event Management
- B) System Integration Event Monitor
- C) Secure Internet Email Manager
- D) Simple Intrusion Event Monitor

Q27. Quel est le cycle opérationnel de détection ?

- A) Collecte → Analyse → Alerte → Investigation → Réponse
- B) Alerte → Collecte → Réponse
- C) Investigation → Alerte → Collecte
- D) Réponse → Analyse → Collecte

Q28. Quel outil est un exemple de NIDS ?

- A) Windows Defender
- B) Snort
- C) Microsoft Word
- D) Photoshop

Q29. Dans quelle phase de la Kill Chain la détection intervient-elle principalement ?

- A) Uniquement à la fin
- B) Reconnaissance, Exploitation, C2, Mouvement latéral, Exfiltration
- C) Jamais
- D) Uniquement au début

Q30. Quel est l'objectif stratégique de la détection ?

- A) Rester réactif
- B) Passer d'une posture réactive à proactive
- C) Ignorer les alertes
- D) Désactiver les systèmes

Q31. Qu'est-ce qu'une règle Snort ?

- A) Une politique RH
- B) Une signature de détection d'attaque
- C) Un protocole réseau
- D) Un algorithme de chiffrement

Q32. Quel scan Nmap utilise le flag -sS ?

- A) TCP Connect scan
- B) SYN scan (half-open)
- C) UDP scan
- D) ICMP scan

Q33. Quel scan Nmap utilise le flag -sT ?

- A) SYN scan
- B) TCP Connect scan
- C) Stealth scan
- D) Null scan

Q34. Que détecte un IDS lors d'un scan de ports ?

- A) Rien
- B) Tentatives de connexion multiples sur différents ports
- C) Uniquement le trafic HTTP
- D) Les emails

Q35. Quelle est la différence entre IDS et IPS ?

- A) Aucune différence
- B) IDS détecte, IPS détecte ET bloque
- C) IPS détecte, IDS bloque
- D) Les deux sont identiques

RÉPONSES PARTIE 2

Q	Réponse
16	B
17	B
18	B
19	B
20	B
21	B
22	B
23	A
24	B
25	B
26	A
27	A
28	B
29	B
30	B
31	B
32	B

Q	Réponse
33	B
34	B
35	B

PARTIE 3 : Réponse à Incident (15 questions)

Q36. Que signifie MTTR ?

- A) Maximum Time To Repair
- B) Mean Time To Respond
- C) Minimum Time To React
- D) Mean Time To Reboot

Q37. Quel cadre de référence est utilisé pour la réponse à incident ?

- A) ISO 9001
- B) NIST SP 800-61
- C) PCI-DSS uniquement
- D) RGPD uniquement

Q38. Combien de phases comporte le cycle NIST de réponse à incident ?

- A) 3
- B) 4
- C) 6
- D) 8

Q39. Quelle est la première phase du cycle NIST ?

- A) Détection
- B) Préparation
- C) Éradication
- D) Récupération

Q40. Que comprend la phase de Préparation ?

- A) Suppression du malware
- B) Politique IR, Playbooks, SOC opérationnel
- C) Restauration des backups
- D) Analyse forensic

Q41. Que fait-on pendant la phase de Confinement ?

- A) On ignore l'incident
- B) Isolation machine, Blocage IP/C2, Segmentation réseau
- C) On restaure les backups
- D) On sensibilise les utilisateurs

Q42. Que signifie REX dans le contexte de la réponse à incident ?

- A) Robot EXpert
- B) Retour d'EXpérience
- C) Remote EXecution
- D) Rapid EXtraction

Q43. Quel rôle SOC effectue le triage initial ?

- A) RSSI
- B) Analyste L1
- C) Incident Manager
- D) Équipe Forensic

Q44. Quel rôle SOC effectue l'investigation approfondie ?

- A) Analyste L1
- B) Analyste L2/L3
- C) Réceptionniste
- D) Développeur

Q45. Quel framework est utilisé pour mapper les techniques d'attaque ?

- A) OWASP
- B) MITRE ATT&CK
- C) ISO 27001
- D) COBIT

Q46. Que fait-on pendant la phase d'Éradication ?

- A) On détecte l'incident
- B) Suppression malware, Patch vulnérabilités, Rotation mots de passe
- C) On prépare les playbooks
- D) On ignore le problème

Q47. Que fait-on pendant la phase de Récupération ?

- A) On détecte l'incident
- B) Restauration backups, Vérification intégrité, Surveillance renforcée
- C) On supprime le malware
- D) On isole les machines

Q48. Pourquoi la réponse rapide est-elle critique ?

- A) Pour économiser de l'argent uniquement
- B) Le temps de réaction détermine l'impact de l'incident
- C) Ce n'est pas important
- D) Pour faire plaisir à la direction

Q49. Quel référentiel marocain traite de la réponse à incident ?

- A) ANSSI
- B) DGSSI Maroc
- C) NIST uniquement
- D) ISO uniquement

Q50. Quel est le cycle cyber simplifié ?

- A) Détection → Réponse → Éradication → Restauration → REX
 - B) Réponse → Détection → REX
 - C) REX → Détection → Réponse
 - D) Éradication uniquement
-

RÉPONSES PARTIE 3

Q	Réponse
36	B
37	B
38	C
39	B
40	B
41	B
42	B
43	B
44	B
45	B
46	B
47	B
48	B
49	B
50	A

PARTIE 4 : Gestion des Vulnérabilités (15 questions)

Q51. Qu'est-ce qu'une vulnérabilité ?

- A) Un virus
- B) Une faiblesse exploitable par une menace
- C) Un pare-feu
- D) Un antivirus

Q52. Quel pourcentage des intrusions exploite des vulnérabilités connues ?

- A) 10-20%
- B) 40-50%

- C) 80-90%
- D) 100%

Q53. Quelle est la différence entre vulnérabilité et exploit ?

- A) Aucune différence
- B) Vulnérabilité = faiblesse technique, Exploit = code d'exploitation
- C) Exploit = faiblesse, Vulnérabilité = code
- D) Les deux sont des virus

Q54. Quel outil est utilisé pour scanner les vulnérabilités ?

- A) Microsoft Word
- B) Nessus, OpenVAS, Qualys
- C) Photoshop
- D) Excel

Q55. Que signifie CVSS ?

- A) Computer Virus Scanning System
- B) Common Vulnerability Scoring System
- C) Central Vulnerability Security Service
- D) Cyber Vulnerability Scan Software

Q56. Combien d'étapes comporte le Vulnerability Management Lifecycle ?

- A) 3
- B) 5
- C) 7
- D) 10

Q57. Quelle est la première étape de la gestion des vulnérabilités ?

- A) Remédiation
- B) Découverte des actifs
- C) Reporting
- D) Scan

Q58. Qu'est-ce que le Shadow IT ?

- A) Un type de malware
- B) Des actifs IT non inventoriés/non autorisés
- C) Un antivirus
- D) Un protocole réseau

Q59. Que signifie "Risk-Based Vulnerability Management" ?

- A) Ignorer tous les risques
- B) Prioriser les vulnérabilités selon le risque métier
- C) Corriger toutes les vulnérabilités en même temps
- D) Ne rien corriger

Q60. Quelle norme ISO traite de la gestion des vulnérabilités ?

- A) ISO 9001
- B) ISO 27001 – A.12.6.1
- C) ISO 14001
- D) ISO 22000

Q61. Quel KPI mesure le temps de correction des vulnérabilités ?

- A) MTTD
- B) MTTR vuln (temps moyen de correction)
- C) ROI
- D) KRI

Q62. Que se passe-t-il sans gestion des vulnérabilités ?

- A) Rien
- B) Reconnaissance → Exploitation → Intrusion
- C) Sécurité parfaite
- D) Moins d'alertes

Q63. Que se passe-t-il avec une gestion efficace des vulnérabilités ?

- A) Plus d'attaques
- B) Reconnaissance → Échec exploitation
- C) Aucun changement
- D) Plus de vulnérabilités

Q64. Qu'est-ce que le patch management ?

- A) Création de malware
- B) Gestion et application des correctifs de sécurité
- C) Suppression des antivirus
- D) Désactivation des pare-feu

Q65. Quel est le message clé de la gestion des vulnérabilités ?

- A) Elle est inutile
- B) C'est le pont entre prévention et détection
- C) Elle augmente les risques
- D) Elle est optionnelle

RÉPONSES PARTIE 4

Q	Réponse
51	B
52	C
53	B

Q	Réponse
54	B
55	B
56	B
57	B
58	B
59	B
60	B
61	B
62	B
63	B
64	B
65	B

PARTIE 5 : Classification des Attaques et Kill Chain (20 questions)

Q66. Qui a créé le modèle Cyber Kill Chain ?

- A) Microsoft
- B) Lockheed Martin (2011)
- C) Google
- D) Apple

Q67. Combien de phases comporte la Cyber Kill Chain ?

- A) 5
- B) 7
- C) 10
- D) 3

Q68. Quelle est la première phase de la Kill Chain ?

- A) Exploitation
- B) Reconnaissance
- C) Installation
- D) C2

Q69. Que signifie "Weaponization" ?

- A) Achat d'armes
- B) Création du malware/exploit (armement)
- C) Livraison du payload
- D) Exfiltration

Q70. Quelle phase correspond à la livraison du malware ?

- A) Reconnaissance
- B) Delivery

- C) Installation
- D) C2

Q71. Que signifie C2 dans la Kill Chain ?

- A) Computer 2
- B) Command & Control
- C) Copy 2
- D) Code 2

Q72. Quelle est la dernière phase de la Kill Chain ?

- A) Reconnaissance
- B) Actions on Objectives
- C) Delivery
- D) Weaponization

Q73. Qu'est-ce qu'une intrusion (tentative) ?

- A) Un succès garanti
- B) Une tentative d'accès non autorisé, peut être bloquée
- C) Un incident confirmé
- D) Une compromission totale

Q74. Qu'est-ce qu'un incident de sécurité ?

- A) Une tentative bloquée
- B) Un événement qui compromet la CIA
- C) Un scan de ports
- D) Une mise à jour système

Q75. Qu'est-ce qu'une compromission ?

- A) Une tentative échouée
- B) Prise de contrôle effective d'un système avec persistance
- C) Un scan de ports
- D) Une alerte IDS

Q76. Quelle est la progression de gravité correcte ?

- A) Compromission → Incident → Intrusion
- B) Intrusion → Incident → Compromission
- C) Incident → Intrusion → Compromission
- D) Toutes sont équivalentes

Q77. Que signifie APT ?

- A) Advanced Protocol Technology
- B) Advanced Persistent Threat
- C) Automatic Penetration Test
- D) Application Programming Tool

Q78. Quelles sont les caractéristiques d'une APT ?

- A) Simple et rapide
- B) Sophistiquée, ciblée, prolongée, acteurs étatiques
- C) Automatique et aléatoire
- D) Sans objectif précis

Q79. Quel groupe APT est associé à la Russie ?

- A) Lazarus Group
- B) APT28, APT29
- C) APT1
- D) Equation Group

Q80. Quel groupe APT est associé à la Corée du Nord ?

- A) APT28
- B) Lazarus Group
- C) APT29
- D) Fancy Bear

Q81. Combien de temps une APT peut-elle rester dans un système ?

- A) Quelques minutes
- B) Des mois ou des années
- C) Quelques secondes
- D) Une heure maximum

Q82. Quel type d'exploit utilisent souvent les APT ?

- A) Exploits publics uniquement
- B) Zero-day exploits
- C) Pas d'exploits
- D) Exploits obsolètes

Q83. Qu'est-ce qu'une attaque DDoS ?

- A) Vol de données
- B) Distributed Denial of Service (attaque sur la disponibilité)
- C) Défacement de site
- D) Phishing

Q84. Quel pilier CIA est affecté par un vol de données ?

- A) Disponibilité
- B) Confidentialité
- C) Intégrité
- D) Aucun

Q85. Quel pilier CIA est affecté par un défacement de site web ?

- A) Confidentialité
 - B) Intégrité
 - C) Disponibilité
 - D) Aucun
-

RÉPONSES PARTIE 5

Q	Réponse
66	B
67	B
68	B
69	B
70	B
71	B
72	B
73	B
74	B
75	B
76	B
77	B
78	B
79	B
80	B
81	B
82	B
83	B
84	B
85	B

PARTIE 6 : Sécurité Défensive vs Offensive (15 questions)

Q86. Qu'est-ce que la Blue Team ?

- A) Équipe offensive
- B) Équipe défensive (protection, détection, réponse)
- C) Équipe de développement
- D) Équipe marketing

Q87. Qu'est-ce que la Red Team ?

- A) Équipe défensive
- B) Équipe offensive (pentest, exploitation)
- C) Équipe support
- D) Équipe RH

Q88. Quel est l'objectif de la Blue Team ?

- A) Attaquer les systèmes
- B) Réduire l'impact d'une attaque
- C) Créer des malwares
- D) Exploiter les vulnérabilités

Q89. Quel est l'objectif de la Red Team ?

- A) Protéger les systèmes
- B) Découvrir les faiblesses avant l'attaquant réel
- C) Gérer les incidents
- D) Installer des antivirus

Q90. Quels outils utilise la Blue Team ?

- A) Metasploit, Cobalt Strike
- B) SIEM, IDS, EDR
- C) Nmap uniquement
- D) Burp Suite uniquement

Q91. Quels outils utilise la Red Team ?

- A) SIEM, EDR
- B) Metasploit, Nmap, Cobalt Strike
- C) Antivirus
- D) Pare-feu

Q92. Qu'est-ce que la Purple Team ?

- A) Une équipe de couleur
- B) Collaboration entre Blue Team et Red Team
- C) Une équipe de développement
- D) Une équipe externe

Q93. Quel est l'objectif de la Purple Team ?

- A) Remplacer Blue et Red
- B) Améliorer la posture sécurité globale
- C) Supprimer les équipes existantes
- D) Ignorer les vulnérabilités

Q94. Quel indicateur clé utilise la Blue Team ?

- A) Taux de compromission
- B) MTTD / MTTR
- C) Nombre d'exploits créés
- D) Nombre de pentests

Q95. Quel indicateur clé utilise la Red Team ?

- A) MTTD
- B) Taux de compromission
- C) Nombre d'alertes
- D) Temps de réponse

Q96. Quel est le message stratégique sur Blue vs Red Team ?

- A) Choisir l'une ou l'autre
- B) Les deux sont complémentaires dans une stratégie unifiée
- C) Red Team est inutile
- D) Blue Team est obsolète

Q97. Que fait la Red Team dans le cycle d'amélioration ?

- A) Détecte
- B) Attaque
- C) Répare
- D) Ignore

Q98. Que fait la Blue Team dans le cycle d'amélioration ?

- A) Attaque
- B) Détecte
- C) Exploite
- D) Ignore

Q99. Qu'est-ce que le Social Engineering ?

- A) Un outil de développement
- B) Manipulation psychologique pour obtenir des informations
- C) Un protocole réseau
- D) Un antivirus

Q100. Qu'est-ce qu'un pentest ?

- A) Un test de performance
- B) Test d'intrusion pour identifier les vulnérabilités
- C) Un test unitaire
- D) Un test de charge

RÉPONSES PARTIE 6

Q	Réponse
86	B
87	B
88	B

Q	Réponse
89	B
90	B
91	B
92	B
93	B
94	B
95	B
96	B
97	B
98	B
99	B
100	B

TABLEAU RÉCAPITULATIF DES RÉPONSES

Question	Réponse	Question	Réponse	Question	Réponse	Question	Réponse
1	B	26	A	51	B	76	B
2	B	27	A	52	C	77	B
3	B	28	B	53	B	78	B
4	B	29	B	54	B	79	B
5	A	30	B	55	B	80	B
6	B	31	B	56	B	81	B
7	B	32	B	57	B	82	B
8	C	33	B	58	B	83	B
9	C	34	B	59	B	84	B
10	B	35	B	60	B	85	B
11	B	36	B	61	B	86	B
12	B	37	B	62	B	87	B
13	B	38	C	63	B	88	B
14	B	39	B	64	B	89	B
15	B	40	B	65	B	90	B
16	B	41	B	66	B	91	B
17	B	42	B	67	B	92	B
18	B	43	B	68	B	93	B
19	B	44	B	69	B	94	B
20	B	45	B	70	B	95	B
21	B	46	B	71	B	96	B
22	B	47	B	72	B	97	B
23	A	48	B	73	B	98	B
24	B	49	B	74	B	99	B
25	B	50	A	75	B	100	B

BARÈME SUGGÉRÉ

- **100-90 points** : Excellent (A)
- **89-80 points** : Très bien (B)
- **79-70 points** : Bien (C)
- **69-60 points** : Passable (D)
- **< 60 points** : Insuffisant (F)

Document généré pour le contrôle de Gestion d'Intrusion